# Northwind BMS API Documentation

เอกสารนี้อธิบาย API ที่มีอยู่จริงในระบบปัจจุบัน ใช้สำหรับทดสอบผ่าน Postman, curl หรือ Front-End

## 1. Base URL และรูปแบบข้อมูล

```
https://northwindbms.site.je/api/index.php
```

เอกสารนี้ระบุ URL สำหรับระบบที่ deploy แล้ว ทุก endpoint ส่งกลับ JSON และ endpoint ที่ต้องล็อกอินใช้ PHP session cookie ชื่อ `northwind_bms` ไม่มี Bearer token

Request body ที่เป็น JSON ใช้ header:

```
Content-Type: application/json
Accept: application/json
```

รูปแบบผลลัพธ์:

```
{
  "success": true,
  "data": {}
}
```

เมื่อเกิดข้อผิดพลาด:

```
{
  "success": false,
  "message": "รายละเอียดข้อผิดพลาด"
}
```

## 2. Authentication และ CSRF

### เข้าสู่ระบบ

`POST /api/index.php?action=login` — ไม่ต้องมี session ก่อนเรียก

Request:

```
{
  "username": "ชื่อผู้ใช้",
  "password": "รหัสผ่าน"
}
```

Response `200`:

```
{
  "success": true,
  "data": {
    "user": {
      "id": 1,
      "username": "admin",
      "display_name": "ผู้ดูแลระบบ"
    },
    "csrf_token": "ค่า token สำหรับส่งใน X-CSRF-Token"
  }
}
```

เซิร์ฟเวอร์สร้าง session cookie ให้โดยอัตโนมัติ เก็บ cookie นี้ไว้ใช้กับคำขอถัดไป

**ตรวจสอบ session ปัจจุบัน**

`GET /api/index.php?action=me` — ต้องเข้าสู่ระบบ

Response `200` มี `data.user` และ `data.csrf_token` เช่นเดียวกับ response การเข้าสู่ระบบ

**ออกจากระบบ**

`POST /api/index.php?action=logout` — ต้องเข้าสู่ระบบและส่ง CSRF token

**เปลี่ยนรหัสผ่าน**

`POST /api/index.php?action=change-password` — ต้องเข้าสู่ระบบและส่ง CSRF token

Request:

```
{
  "old_password": "รหัสผ่านเดิม",
  "new_password": "รหัสผ่านใหม่อย่างน้อย 10 ตัวอักษร"
}
```

**CSRF สำหรับการเปลี่ยนแปลงข้อมูล**

ทุก `POST`, `PUT` และ `DELETE` นอกจาก `POST action=login` ต้องมี session cookie และ header:

```
X-CSRF-Token: <csrf_token จาก action=me หรือ action=login>
```

## 3. Endpoint สำหรับข้อมูล

| HTTP | URL | การทำงาน | ต้องล็อกอิน |
|---|---|---|---|
| `GET` | `?resource={resource}` | อ่านรายการ | ใช่ |
| `GET` | `?resource={resource}&id={id}` | อ่านรายการเดียว | ใช่ |
| `POST` | `?resource={resource}` | เพิ่มรายการ | ใช่ + CSRF |
| `PUT` | `?resource={resource}&id={id}` | แก้ไขเฉพาะฟิลด์ที่ส่งมา | ใช่ + CSRF |
| `DELETE` | `?resource={resource}&id={id}` | ลบรายการ | ใช่ + CSRF |

รองรับ CRUD ตามตารางนี้:

| `resource` | ฟิลด์ที่ต้องส่งเมื่อสร้าง ( `POST` ) | รูปแบบข้อมูลที่อ่านได้ |
|---|---|---|
| `products` | `c_ProductName` (สูงสุด 30 ตัวอักษร), `i_SupplierID` (integer), `i_CategoryID` (integer), `c_Unit` (สูงสุด 30 ตัวอักษร), `i_Price` (number ตั้งแต่ 0) | `id`, `name`, `supplier_id`, `supplier`, `category_id`, `category`, `unit`, `price` |
| `categories` | `c_CategoryName` (สูงสุด 30 ตัวอักษร), `c_Description` (สูงสุด 30 ตัวอักษร) | `id`, `name`, `description`, `product_count` |
| `customers` | `c_customername` (สูงสุด 50), `c_contactname` (สูงสุด 50), `c_address`, `c_city` (สูงสุด 50), `c_postalcode` (สูงสุด 30), `c_country` (สูงสุด 50) | `id`, `name`, `contact`, `address`, `city`, `postal_code`, `country`, `order_count` |

| resource | ฟิลด์ที่ต้องส่งเมื่อสร้าง ( POST ) | รูปแบบข้อมูลที่อ่านได้ |
|---|---|---|
| suppliers | c_SupplierName, c_ContactName, c_Address, c_City, c_PostalCode, c_Country, c_Phone (ฟิลด์ที่กำหนดจำกัดมีความยาวสูงสุด 30) | id, name, contact, address, city, postal_code, country, phone, product_count |
| employees | c_LastName, c_FirstName, c_BirthDate, c_Photo (สูงสุดฟิลด์ละ 30), c_Notes (สูงสุด 80) | id, first_name, last_name, birth_date, photo, notes, order_count |
| shippers | c_ShipperName, c_Phone (สูงสุดฟิลด์ละ 30) | id, name, phone, order_count |

ฟิลด์อื่น ๆ ใน request body ที่ไม่ได้อยู่ในรายการของ resource นั้นจะไม่ถูกบันทึก สร้างรายการสินค้าแล้วระบบออก id ให้อัตโนมัติ ส่วน categories, customers, suppliers, employees และ shippers ใช้รหัสถัดไปจากข้อมูลในตาราง

ตัวอย่างอ่านสินค้า:

```
GET /api/index.php?resource=products
```

Response 200:

```
{
  "success": true,
  "data": [
    {
      "id": 1,
      "name": "Chai",
      "supplier_id": 1,
      "supplier": "Exotic Liquids",
      "category_id": 1,
      "category": "เครื่องดื่ม",
      "unit": "10 boxes x 20 bags",
      "price": "18.00"
    }
  ]
}
```

ตัวอย่างเพิ่มสินค้า:

```
POST /api/index.php?resource=products
X-CSRF-Token: <csrf_token>
```

```
{
  "c_ProductName": "สินค้าใหม่",
  "i_SupplierID": 1,
  "i_CategoryID": 1,
  "c_Unit": "10 boxes",
  "i_Price": 25.5
}
```

Response 201:

```
{
  "success": true,
  "data": {
    "id": 80
  }
}
```

การแก้ไขใช้ PUT ?resource=categories&id=1 และส่งเฉพาะฟิลด์ที่ต้องการแก้ เช่น {"c_CategoryName":"เครื่องดื่ม"} การลบใช้ DELETE ?resource=categories&id=1 รายการที่มีข้อมูลอื่นอ้างอิงอยู่จะลบไม่ได้และตอบ 409

## 4. ค้นหาและรายการพิเศษ

### ค้นหา resource

เพิ่ม `q` ในคำขอ `GET` ของ resource ทั่วไป:

```
GET /api/index.php?resource=products&q=chai
```

ค้นหาแบบข้อความในฟิลด์ค้นหาของ resource นั้น ๆ ได้แก่ products (ชื่อ/ผู้จัดจำหน่าย/หมวดหมู่/หน่วย), categories (ชื่อ/รายละเอียด), customers (ชื่อ/ผู้ติดต่อ/เมือง/ประเทศ), suppliers (ชื่อ/ผู้ติดต่อ/เมือง/ประเทศ/โทรศัพท์), employees (ชื่อ/นามสกุล/หมายเหตุ) และ shippers (ชื่อ/โทรศัพท์)

### คำสั่งซื้อ

- `GET ?resource=orders` อ่านรายการคำสั่งซื้อ
- `GET ?resource=orders&id={id}` อ่านคำสั่งซื้อเดียวพร้อม `items`
- `POST ?resource=orders` สร้างคำสั่งซื้อพร้อมสินค้า

ตัวกรองรายการ `GET orders` ที่รองรับ:

| Query | ชนิด | รายละเอียด |
|---|---|---|
| `q` | string | ค้นหาเลขที่คำสั่งซื้อ ลูกค้า พนักงาน หรือบริษัทขนส่ง |
| `status` | string | `มีรายการสินค้า` หรือ `ไม่มีรายการสินค้า` |
| `from` | `YYYY-MM-DD` | วันเริ่มต้น (รวมวันนั้น) |
| `to` | `YYYY-MM-DD` | วันสิ้นสุด (รวมวันนั้น) |

Request สำหรับสร้างคำสั่งซื้อ:

```
{
  "customer_id": 1,
  "employee_id": 1,
  "shipper_id": 1,
  "order_date": "2026-10-30",
  "items": [
    {
      "product_id": 1,
      "quantity": 2
    }
  ]
}
```

ต้องมีลูกค้า พนักงาน บริษัทขนส่ง และสินค้าอยู่ในระบบ วันที่ใช้รูปแบบ `YYYY-MM-DD` และจำนวนสินค้าต้องเป็น integer ตั้งแต่ 1 ขึ้นไป ระบบสร้างคำสั่งซื้อและรายการสินค้าภายใน transaction เดียว

Response `201`:

```
{
  "success": true,
  "data": {
    "id": 10443
  }
}
```

### รายละเอียดสินค้าในคำสั่งซื้อ

`GET /api/index.php?resource=order-details&order_id={order_id}`

ส่งกลับ array ของ `product_id`, `product_name`, `quantity`, `unit_price` และ `line_total`

**รายงาน**

`GET /api/index.php?resource=reports` อ่านรายงานทุกปี หรือระบุปี ค.ศ. ด้วย `year` เช่น `?resource=reports&year=1997`

`data` มี `summary` (`order_count`, `revenue`, `average_order`, `customer_count`, `popular_shipper`, `popular_shipper_orders`) และ array `top_products`, `top_customers`, `top_employees` (สูงสุด 5 รายการต่อกลุ่ม)

## 5. ตัวอย่าง Response และ HTTP Status

| Status | ความหมาย |
|---|---|
| `200` | สำเร็จ |
| `201` | สร้างข้อมูลสำเร็จ |
| `400` | query parameter หรือรูปแบบคำขอไม่ถูกต้อง |
| `401` | ยังไม่เข้าสู่ระบบ หรือข้อมูลเข้าสู่ระบบไม่ถูกต้อง |
| `404` | ไม่พบ endpoint หรือรายการ |
| `409` | ข้อมูลขัดกับความสัมพันธ์ในฐานข้อมูล หรือลบรายการที่มีข้อมูลอ้างอิง |
| `419` | CSRF token ไม่ถูกต้องหรือ session หมดอายุ |
| `422` | ข้อมูลไม่ครบหรือไม่ผ่าน validation |
| `503` | ยังไม่ได้ตั้งค่าหรือเชื่อมต่อฐานข้อมูลไม่ได้ |

ตัวอย่าง error:

```
{
  "success": false,
  "message": "กรุณากรอกข้อมูลให้ครบถ้วน"
}
```